



PDF Download
3702973.pdf
10 March 2026
Total Citations: 46
Total Downloads:
2857

Latest updates: <https://dl.acm.org/doi/10.1145/3702973>

RESEARCH-ARTICLE

When ChatGPT Meets Smart Contract Vulnerability Detection: How Far Are We?

CHONG CHEN, Sun Yat-Sen University, Guangzhou, Guangdong, China

JIANZHONG SU, Sun Yat-Sen University, Guangzhou, Guangdong, China

JIACHI CHEN, Sun Yat-Sen University, Guangzhou, Guangdong, China

YANLIN WANG, Sun Yat-Sen University, Guangzhou, Guangdong, China

TINGTING BI, The University of Western Australia, Perth, WA, Australia

JIANXING YU, Sun Yat-Sen University, Guangzhou, Guangdong, China

[View all](#)

Open Access Support provided by:

Sun Yat-Sen University

University of Electronic Science and Technology of China

Zhejiang University

The University of Western Australia

Published: 28 April 2025

Online AM: 05 November 2024

Accepted: 11 October 2024

Revised: 14 August 2024

Received: 11 September 2023

[Citation in BibTeX format](#)

When ChatGPT Meets Smart Contract Vulnerability Detection: How Far Are We?

CHONG CHEN, Sun Yat-sen University, Guangzhou, China and The State Key Laboratory of Blockchain and Data Security, Zhejiang University, Hangzhou, China

JIANZHONG SU, Sun Yat-sen University, Guangzhou, China

JIACHI CHEN, Sun Yat-sen University, Guangzhou, China and The State Key Laboratory of Blockchain and Data Security, Zhejiang University, Hangzhou, China

YANLIN WANG, Sun Yat-sen University, Guangzhou, China

TINGTING BI, University of Western Australia, Perth, Australia

JIANXING YU and **YANLI WANG**, Sun Yat-sen University, Guangzhou, China

XINGWEI LIN, Zhejiang University, Hangzhou, China

TING CHEN, University of Electronic Science and Technology of China, Chengdu, China

ZIBIN ZHENG, Sun Yat-sen University, Guangzhou, China

With the development of blockchain technology, smart contracts have become an important component of blockchain applications. Despite their crucial role, the development of smart contracts may introduce vulnerabilities and potentially lead to severe consequences, such as financial losses. Meanwhile, large language models, represented by ChatGPT, have gained great attention, showcasing great capabilities in code analysis tasks. In this article, we presented an empirical study to investigate the performance of ChatGPT in identifying smart contract vulnerabilities. Initially, we evaluated ChatGPT's effectiveness using a publicly available smart contract dataset. Our findings discover that while ChatGPT achieves a high recall rate, its precision in pinpointing smart contract vulnerabilities is limited. Furthermore, ChatGPT's performance varies when detecting different vulnerability types. We delved into the root causes for the false positives generated by ChatGPT, and categorized them into four groups. Second, by comparing ChatGPT with other state-of-the-art smart contract vulnerability detection tools, we found that ChatGPT's F-score is lower than others for 3 out of the 7 vulnerabilities. In the case of the remaining 4 vulnerabilities, ChatGPT exhibits a slight advantage over these tools. Finally, we analyzed the limitation of ChatGPT in smart contract vulnerability detection,

This work was supported by the Open Research Fund of The State Key Laboratory of Blockchain and Data Security, Zhejiang University and the National Natural Science Foundation of China (62332004, 62276279) and Guangdong Basic and Applied Basic Research Foundation (2024B1515020032).

Authors' Contact Information: Chong Chen, Sun Yat-sen University, Guangzhou, China and The State Key Laboratory of Blockchain and Data Security, Zhejiang University, Hangzhou, China; e-mail: chench578@mail2.sysu.edu.cn; Jianzhong Su, Sun Yat-sen University, Guangzhou, China; e-mail: sujzh3@mail2.sysu.edu.cn; Jiachi Chen (corresponding author), Sun Yat-sen University, Guangzhou, China and The State Key Laboratory of Blockchain and Data Security, Zhejiang University, Hangzhou, China; e-mail: chenjch86@mail.sysu.edu.cn; Yanlin Wang, Sun Yat-sen University, Guangzhou, China; e-mail: wangylin36@mail.sysu.edu.cn; Tingting Bi, University of Western Australia, Perth, Australia; e-mail: Tingting.Bi@uwa.edu.au; Jianxing Yu, Sun Yat-sen University, Guangzhou, China; e-mail: yujx26@mail.sysu.edu.cn; Yanli Wang, Sun Yat-sen University, Guangzhou, China; e-mail: wangyli58@mail2.sysu.edu.cn; Xingwei Lin, Zhejiang University, Hangzhou, China; e-mail: xwlin.roy@gmail.com; Ting Chen, University of Electronic Science and Technology of China, Chengdu, China; e-mail: brokendragon@uestc.edu.cn; Zibin Zheng, Sun Yat-sen University, Guangzhou, China; e-mail: zhzibin@mail.sysu.edu.cn.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, to republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

© 2025 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM 1557-7392/2025/4-ART100

<https://doi.org/10.1145/3702973>

revealing that the robustness of ChatGPT in this field needs to be improved from two aspects: its *uncertainty* in answering questions; and the *limited length* of the detected code. In general, our research provides insights into the strengths and weaknesses of employing large language models, specifically ChatGPT, for the detection of smart contract vulnerabilities.

CCS Concepts: • **Security and privacy** → *Software security engineering*;

Additional Key Words and Phrases: Empirical Study, Smart Contracts, Large Language Models, ChatGPT, Vulnerabilities

ACM Reference format:

Chong Chen, Jianzhong Su, Jiachi Chen, Yanlin Wang, Tingting Bi, Jianxing Yu, Yanli Wang, Xingwei Lin, Ting Chen, and Zibin Zheng. 2025. When ChatGPT Meets Smart Contract Vulnerability Detection: How Far Are We? *ACM Trans. Softw. Eng. Methodol.* 34, 4, Article 100 (April 2025), 30 pages.
<https://doi.org/10.1145/3702973>

1 Introduction

In recent years, with the rapid development of blockchain platforms (e.g., Ethereum), smart contracts have been widely adopted in various domains [78]. However, the security issues arising from smart contract vulnerabilities have also resulted in significant economic losses [59]. These security concerns not only directly harm users' funds but also have adverse effects on the overall development of the blockchain ecosystem. Therefore, detecting vulnerabilities in smart contracts has become an important task in recent years.

Meanwhile, the introduction of ChatGPT [48], a **Large Language Model (LLM)** developed by the OpenAI team [66], has made a significant impact in various fields. ChatGPT's potential in computer programming has attracted significant attention in recent research [6]. Some recent studies have explored the applicability of LLM in vulnerability detection [38, 60]. While there has been considerable analysis of ChatGPT's code capabilities in previous work, research on smart contract vulnerability detection remains relatively limited. In addition to ChatGPT, common LLM models include LLaMA [71] and PaLM2 [4]. LLaMA is a collection of foundation language models ranging from 7B to 65B parameters. PaLM2 is an LLM that builds on Google's [65] legacy of breakthrough research in machine learning and responsible artificial intelligence. Considering that GPT [49] was among the first commercially available LLMs and continues to be widely used, it was our choice for this research.

In this work, we embarked on empirical research focused on smart contract vulnerability detection using ChatGPT. To explore the capabilities of ChatGPT in analyzing, understanding, and detecting smart contract vulnerabilities, we conducted an empirical study on its effectiveness, limitations, and comparison with other state-of-the-art smart contract vulnerability detection tools. In our exploration of using the GPT model for smart contract vulnerability detection, we initiated the assessment by evaluating its effectiveness using the widely used smartbugs dataset [16]. Subsequently, we conducted a comparative analysis of the detection performance of the GPT model against 14 other SOTA tools. Lastly, we examined the limitations associated with applying GPT in the realm of smart contract vulnerability detection. Figure 1 provides an overview of our research methodology. We focus on the following **research questions (RQs)**:

RQ1. How effective is ChatGPT in detecting vulnerabilities in smart contracts?

We selected the widely used smartbugs-curated dataset [16], which comprises 142 vulnerable smart contracts. The dataset contains nine categories of vulnerabilities as described in DASP10 [75]. We designed a prompt for ChatGPT to detect these nine categories of vulnerability. The effectiveness of vulnerability detection is evaluated through various metrics (i.e., precision, recall,

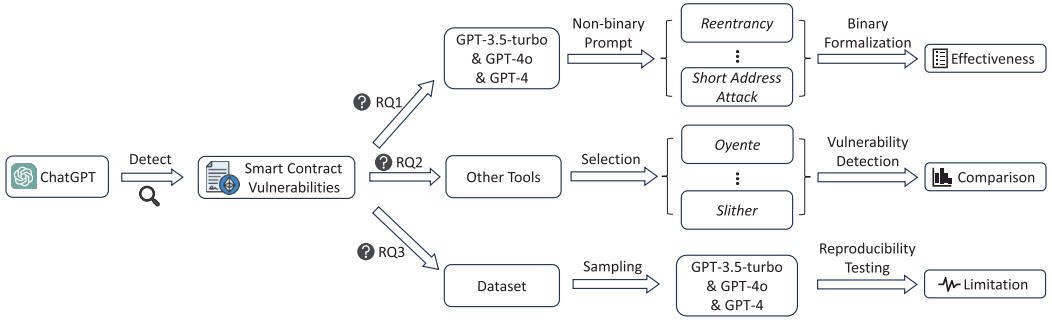


Fig. 1. The overview of our research.

and F-score). Our findings indicated that while ChatGPT achieves a promising recall rate (i.e., 51.4%, 83.6% and 88.2% for GPT-3.5, GPT-4o and GPT-4, respectively), its precision in pinpointing smart contract vulnerabilities is relatively low (19.7%, 20.2% and 22.6% for GPT-3.5, GPT-4o and GPT-4, respectively). In addition, the detection performance of ChatGPT varies across different types of vulnerabilities. For example, GPT-3.5, GPT-4o and GPT-4 all perform well in detecting *Unchecked Return Values* [28], however, all of them perform poorly in identifying *Short Address Attack* [10]. Furthermore, we conducted a systematic analysis of **false positives (FP)** within ChatGPT, categorizing them into 4 distinct types: *Protected Mechanism Bias*, *Development Intent Bias*, *Interfered by Comments* and *Interference with Dead Code*.

RQ2. How does ChatGPT perform compared to other tools?

In RQ1, we focus only on ChatGPT's effective in detecting certain vulnerabilities. To fully understand the level of capability of ChatGPT, it is important to compare its performance against other state-of-the-art tools. Through comparative analysis, we can elucidate the relative strengths and limitations of ChatGPT within the domain of vulnerability detection, thereby providing insights to inform future tool selection and development efforts. To evaluate ChatGPT's performance compared to other state-of-the-art smart contract vulnerability detection tools, we employed 14 vulnerability tools (e.g., Mythril [12] and Confuzzius [68]) on the same smartbugs-curated [16] dataset. Our results show that although ChatGPT outperformed other 14 tools in detecting specific vulnerabilities like *Front Running* and *denial of service*, the F1 scores are relatively low, measuring only 12.8% and 15.9%, respectively. For other vulnerability types, several tools demonstrate more effective detection capabilities than ChatGPT. However, in terms of detection speed, ChatGPT surpasses all other tools. Still, ChatGPT's detection failure rate surpasses that of 10 other tools due to the token limitations of LLMs.

RQ3. What are the limitations of ChatGPT in detecting smart contract vulnerabilities?

As an artificial intelligence dialogue model, ChatGPT may produce different vulnerability detection results for the same smart contract when provided with the same prompt, potentially diminishing its reliability. To evaluate its reliability, we randomly sampled 50 smart contracts in the smartbugs-curated [16] dataset and conducted vulnerability detection on them for five times with the same prompt. Our analysis showed that only 29 out of 50 contracts displayed entirely consistent results across all five round of detection. This suggests that 42% of the evaluated smart contracts exhibit unstable detection outcomes. Additionally, the official documentation specifies the maximum token limit that the GPT model can handle. However, it does not provide precise information about limit of the associated code size, leaving developers without clear guidance on this aspect. As a result, we conducted experiments on both the gpt-3.5-turbo and gpt-4 models to approximate the maximum code size they can accommodate.

We summarized our main contributions as follows:

- We applied the gpt-3.5-turbo, the gpt-4o and the gpt-4 model to perform vulnerability detection on the smartbugs-curated dataset to evaluate their effectiveness. We provided evidence that ChatGPT has different detection performance for different vulnerabilities, with a relatively high recall rate but low precision. We also summarized 4 root causes of the FP generated by ChatGPT.
- We compared ChatGPT with 14 smart contract vulnerability detection tools in terms of effectiveness and efficiency. By conducting tests on 142 smart contracts, we identified two key insights into the strengths and limitations of ChatGPT. These insights represent valuable contributions to the ongoing research in leveraging LLM for vulnerability detection.
- We evaluated stability of ChatGPT in detecting smart contract vulnerabilities, revealing that it is still uncertain in generating results of vulnerability detection. Additionally, we estimated the maximum code size that can be accommodated by both gpt-3.5-turbo and gpt-4.
- We made all experimental data publicly (i.e., Zenodo repository: <https://zenodo.org/record/8332273>), which could provide a guideline for developers and researchers to conduct the similar experiments for smart contract vulnerability detection.

The organization of the rest of this article is as follows. In Section 2, we provided background information on smart contracts and some common vulnerabilities in them. In Sections 3, 4, and 5, we elaborated on the experiments and conclusions of each RQ in detail. Specifically, in Section 3, we elaborated on the research on the effectiveness of ChatGPT in detecting smart contract vulnerabilities. In Section 4, we compared the performance of ChatGPT with multiple current smart contract vulnerability detection tools on the same dataset. In Section 5, we conducted research on the limitations of ChatGPT in detecting smart contract vulnerabilities. In Section 6, some aspects of this study are discussed. In Section 7, we presented some related work. In Section 8, we summarized this study and provided future prospects.

2 Background

In this section, we briefly introduced background information about smart contracts and some common vulnerabilities.

2.1 Smart Contract

Smart contracts are automated execution protocols based on blockchain technology whose results can be widely recognized and agreed upon. The concept of smart contracts was initially introduced by Szabo in 1997 [64]. This concept describes smart contracts as programs that facilitate digital verification without the need for trust and are self-executing. Accordingly, unlike traditional programs, smart contracts can be executed without the involvement of arbitrators or third-party institutions. Smart contracts are typically developed using high-level programming languages, such as **Solidity** [13], the most popular language for programming Ethereum smart contracts.

2.2 Smart Contract Vulnerabilities

Smart contract vulnerabilities refer to security flaws or loopholes present in the smart contract, which can be exploited to manipulate contract rules or steal assets [30]. Due to the immutability of blockchain, once the smart contract is deployed on the blockchain, the code cannot be changed anymore, even the vulnerability is detected. Therefore, it may be maliciously exploited or cause irreparable economic losses [59].

Decentralized Application Security Project (DASP) [75] is an initiative of the National Computing Centre Group. It is an open and collaborative project to join efforts to discover smart contract

Table 1. Top 9 Smart Contract Vulnerabilities in DASP10 and Their Corresponding Descriptions and Levels

Vulnerability	Description	Level
Reentrancy (RE)	Reentrant function calls make a contract to behave in an unexpected way	Solidity
Access Control (AC)	Failure to use function modifiers or use of tx.origin	Solidity
Arithmetic Issues (AI)	Integer over/underflows	Solidity
Unchecked Return Values (UR)	call(), callcode(), delegatecall() or send() fails and it is not checked	Solidity
Denial Of Service (DoS)	The contract is overwhelmed with time-consuming computations	Solidity
Bad Randomness (BR)	Malicious miner biases the outcome	Blockchain
Front Running (FR)	Two dependent transactions that invoke the same contract are included in one block	Blockchain
Time Manipulation (TM)	The timestamp of the block is manipulated by the miner	Blockchain
Short Address Attack (SAA)	EVM itself accepts incorrectly padded arguments	EVM

“Solidity” level vulnerabilities are issues in how the contract is coded “EVM” level ones come from the EVM execution model. “Blockchain” level ones are inherent to public blockchains.

vulnerabilities within the security community. DASP10 introduces 10 common vulnerabilities in smart contracts, such as reentrancy, access control, etc. Table 1 lists the top 9 vulnerabilities in this list. The 10th type of vulnerability, known as Unknown Unknowns, refers to other vulnerabilities that may occur during iterative updates of smart contracts and will not be discussed further here.

Smartbugs-curated dataset [16] is based on the DASP taxonomy. It provides a collection of vulnerable Solidity smart contracts organized according to the DASP taxonomy, as shown in Table 1. The first column of the table is the vulnerability name, the second column is the corresponding description, and the third column is the severity level. Specifically, Smartbugs-curated is a dataset provided by the Smartbugs project team containing 142 smart contracts, each contract code labeled with the specified vulnerability type. These contracts have certain representativeness and importance and can be used to test and verify the effectiveness of vulnerability detection tools. There are multiple sources of contracts in the dataset, including Ethereum and other public blockchain applications. Our research is based on the DASP10 and smartbugs-curated datasets.

2.3 ChatGPT

LLMs represent a pivotal advancement in **natural language processing (NLP)**, revolutionizing various tasks like text generation, question answering, and dialogue systems. Among these, ChatGPT [48], developed by OpenAI [66], stands out as a leading LLM, building upon the successes of the GPT series, notably GPT-3.5 and GPT-4 [48]. While numerous LLMs continue to emerge, including ChatGLM [15], Xunfei-Xinghuo [3], and ChatYuan-Large [1], etc., studies indicate that ChatGPT consistently outperforms these models in terms of performance across most tasks [77].

ChatGPT [48] is an LLM developed by OpenAI [66] company, which is an upgraded product of the GPT [49] series of models. ChatGPT uses deep learning structures such as transformers [39] to pre-train and learn the statistical laws of language on large-scale text datasets. On this basis, perform task fine-tuning to gain powerful language processing capabilities such as text generation, question answering, and dialogue. During the training process, ChatGPT collected a large amount of text data from the Internet. The core principle of ChatGPT is the use of the Transformer [39] architecture, which is an advanced neural network structure that enables the model to understand context, capture semantic correlations, and exhibit impressive intelligence when answering questions or generating text. The emergence of ChatGPT marks further progress in language understanding and the generation of large models. Currently, there are two widely used models for the GPT series: GPT-3.5 and GPT-4.

GPT-3.5. GPT-3.5 is an upgraded version of GPT-3 with fewer parameters that includes a fine-tuning process for machine learning algorithms [41]. The fine-tuning process involves Reinforcement Learning [34] with human feedback, which helps to improve the accuracy and effectiveness

of the algorithms. The most capable and cost-effective model in the GPT-3.5 family is *gpt-3.5-turbo* which has been optimized for chat but also works well for traditional completion tasks [46].

GPT-4. Like previous GPT models, the GPT-4 base model was trained to predict the next word in a document and was trained using publicly available data (such as internet data) and data the OpenAI team has licensed [50]. Moreover, it is a large-scale multimodal model that accepts input of image and text and outputs text [48]. The GPT-4 model has a larger model size (1.76 trillion parameters [50]) and better architecture, which can help it better understand the code, thus identifying potential problems more accurately. GPT-4o [51] is an optimized version of GPT-4, designed to be more efficient in terms of computational resources while maintaining a similar or slightly reduced performance level. It's often used in contexts where the full power of GPT-4 is not necessary, allowing for faster inference times and reduced costs.

This study only focused on the *gpt-3.5-turbo* [46], *gpt-4o* [51] and *gpt-4* [47] models mentioned above; nonetheless, updated versions of the models will emerge. Even with model updates, there exists a degree of stability. While the performance of models may undergo slight changes, some insights and discoveries remain significant. Model updates often enhance their overall understanding of large-scale corpora but may not necessarily yield substantial performance improvements in specific tasks. Therefore, our research results retain their reference value. Additionally, our findings also offer insights for other models, such as *Claude* [5] and *Llama* [71], as they share training principles with the models we utilized.

3 (RQ1) on Effectiveness of ChatGPT in Detecting Vulnerabilities

In this section, we explore the effectiveness of ChatGPT in detecting smart contract vulnerabilities with various metrics (i.e., precision, recall, and F1 score). We evaluate the performance of ChatGPT based on the top 9 smart contract vulnerabilities from the DASP10.

3.1 Dataset

We use the *smartbugs-curated* [16] for our analysis. This dataset was chosen for the following key reasons: (1) its prevalent use within the smart contract vulnerability detection community [16, 23]; (2) each contract is meticulously labeled with associated vulnerabilities, ensuring the high-quality of data; (3) the straightforward nature of the dataset makes it suitable for the initial assessment of ChatGPT's vulnerability detection capabilities. Specifically, the average line of code of the contracts in the dataset is about 101.5 rows. *Smartbugs-curated provides a collection of vulnerable Solidity smart contracts* organized according to the DASP taxonomy, as shown in Table 1. For more information on the types of vulnerability detected and dataset in this experiment, refer to Section 2.2. It is important to note that all contracts in the dataset are flagged with vulnerabilities (positive), albeit with different types present in each. Our experiment focuses on specific vulnerability types within the contracts (e.g., when detecting *reentrancy* vulnerability, contracts lacking such vulnerability are considered negative). Therefore, during testing, we evaluate the entire dataset as a unit. Contracts featuring a particular vulnerability type are labeled as positive, while those devoid of said vulnerability are labeled as negative.

3.2 Experiment

In order to evaluate the effectiveness of ChatGPT in detecting smart contract vulnerabilities, we use the GPT model API [49] to establish dialogue with the model. The models used in our experiment are the *gpt-3.5-turbo-0613* model [46], the *gpt-4o-2024-05-13* model [51] and the *gpt-4-0613* model [47]. They are all the latest models in their respective series by the time of writing the article. The parameter of *temperature* was configured at 0.7 to strike a delicate equilibrium between fostering innovation and ensuring stability during text generation. All other parameters were maintained at

Table 2. Introduction to the Two Models Used in the Experiment

Model	Description	Max Tokens	Training Data
gpt-3.5-turbo-0613	Snapshot of gpt-3.5-turbo from June 13th 2023 with function calling data.	4,096 tokens	Up to Sep 2021
gpt-4o-2024-05-13	High-intelligence flagship model for complex, multi-step tasks. GPT-4o is cheaper and faster than GPT-4 Turbo.	4,096 tokens	Up to Oct 2023
gpt-4-0613	Snapshot of gpt-4 from June 13th 2023 with function calling data.	8,192 tokens	Up to Sep 2021

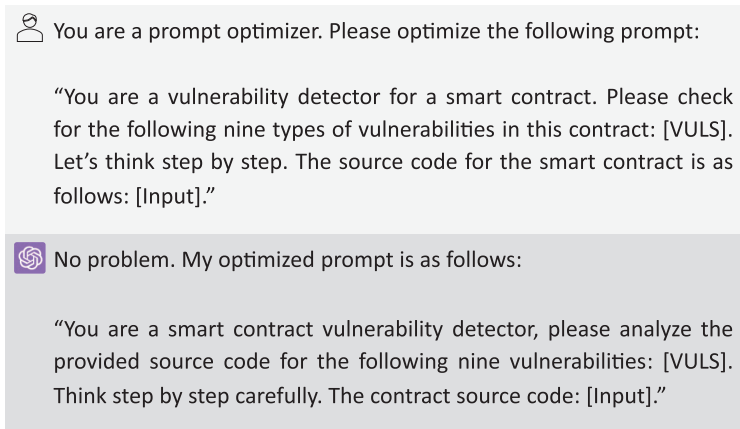


Fig. 2. An example of prompt optimization using the GPT-4 model.

their default values (e.g., *TopP* set to 1 and *FrequencyPenalty* set to 0). Table 2 provides information on the three models.

Models based on GPT architecture rely on a prompt-based learning approach [40]. The effectiveness of the prompts significantly affects the overall performance of the models. To enhance the quality of the prompts, we employ ChatGPT to optimize our initial prompts and subsequently consolidate the generated prompts. In our study, we instruct ChatGPT to be a prompt optimizer with the task of optimizing the given prompt. This process helps us to generate refined prompts. We use the GPT model to generate multiple draft prompts, which undergo manual evaluation using sampled data to discern variances and derive high-quality prompts. Figure 2 provides an illustration of prompt optimization using the GPT-4 model. In the context of smart contract vulnerability detection, we initiate the process by composing an initial task description. This draft prompt is then fed into the GPT-4 model for optimization, resulting in an optimized version of the draft. We sampled 20 smart contracts from the smartbugs-curated dataset [16] and tried to use different versions of the GPT-optimized prompts to instruct itself to perform vulnerability detection tasks. In the end, the optimal prompt template was distilled as follows:

You are [ROLE]. [TASK DESCRIPTION]. Think step by step, carefully. The input is [INPUT].

Table 3. Evaluation of GPT-3.5-Turbo Detection Results on the Dataset (Restricted Output)

Vulnerability	Precision	Recall	F-measure
Reentrancy	26.0%	38.0%	31.5%
Access Control	12.5%	65.0%	21.0%
Arithmetic Issues	92.0%	60.0%	72.5%
Unchecked Return Values	75.0%	25.0%	37.5%
Denial of Service	9.5%	80.0%	17.0%
Bad Randomness	95.0%	20.0%	33.3%
Front Running	2.0%	15.0%	3.6%
Time manipulation	8.0%	70.0%	14.5%
Short Address Attack	0.0%	0.0%	0.0%

where the placeholder [ROLE] denotes the specific role assigned to ChatGPT. In this study, two main roles were designated: *smart contract vulnerability detector* and *text semantic analyzer*. *smart contract vulnerability detector* is used to detect smart contract vulnerability tasks. The function of *text semantic analyzer* is to perform semantic analysis on the conclusion of GPT detecting smart contract vulnerabilities, and achieve binary output of the detection conclusion (i.e., use “1” to indicate the existence of the vulnerability, and “0” to indicate the absence). We have created a new session to use this role, with the aim of avoiding the impact of context on the model. [TASK DESCRIPTION] describes the expected task that ChatGPT will perform. [INPUT] serves as a placeholder for the code under analysis.

We used the template above and provided the corresponding contract source code and command model to perform vulnerability detection tasks. In addition, in the prompt, we limited the scope of vulnerabilities to be detected for comparison with the ground truth in the dataset. The prompt template used is shown as follows:

You are a **vulnerability detector for a smart contract**. Here are **nine common vulnerabilities**. [VULS]. Check the following smart contract for the above **vulnerabilities**. Think step by step, carefully. The input is [INPUT].

where [VULS] represents an introduction to the 9 vulnerabilities that need to be detected in this study. The introduction provides the names of each vulnerability along with their aliases, and this information is sourced from the official DASP10 website [75]. [INPUT] represents the source code of the smart contract to be detected.

Without specific constraints, ChatGPT can produce responses in a non-standardized format, which poses challenges for extracting coherent and meaningful insights. To enable a more systematic analysis of vulnerability detection results, one effective approach is to include commands in the prompt to limit the output format. However, imposing such format restrictions directly within prompts may also affect the performance of vulnerability detection in LLMs. To explore whether restricting the format of the ChatGPT output would affect its vulnerability detection performance, we conducted an experiment on the entire dataset using the gpt-3.5-turbo model, while limiting the output format.

Under the condition of limited output, the experimental result of gpt-3.5-turbo is shown in Table 3. From the comparison between Table 3 and the left part of Table 5, it can be seen that, except for the vulnerability of *Arithmetic Issues*, the limitation of the output format has a negative impact on the vulnerability detection performance of ChatGPT in all other vulnerabilities.

Table 4. Result of Semantic Analysis and Standardizing Output Formats of the GPT Model on 50 Sampled Data

Result	Number	Description
Correct	47	Completely consistent
Omissions	2	Missing some vulnerabilities inference included in original conclusions
Hallucination	1	Generating some vulnerabilities inference not included in original conclusion

Finding 1: Across the spectrum of eight vulnerability types, the vulnerability detection performance of ChatGPT may decrease due to output format limitations, indicating that limitations on ChatGPT output format may affect its ability.

Based on Finding 1, we attempted to use the inherent capabilities of LLMs to refine the output. Specifically, once we obtained the vulnerability detection results from an LLM, we initiated a new conversation, feeding those results back into the model for semantic analysis. This ensures that the vulnerability detection output adheres to a unified format of “[VUL]: 0/1.” The prompt template for this round of conversation is as follows:

You are a **semantic analyzer of text**. Here are nine common vulnerabilities. [VULS]. The following text is a vulnerability detection result for a smart contract. Use 0 or 1 to indicate whether there are specific types of vulnerabilities. For example: “Reentrancy: 1”. Think step by step, carefully. The input is [INPUT].

The effectiveness of the semantic analysis process requires validation. For example, if the GPT model identifies a contract as having both *Reentrancy* and *Arithmetic Issues* vulnerabilities, but the semantic analysis outcome indicates “*Reentrancy*: 1, *Arithmetic Issues*: 0,” this renders the semantic analysis ineffective. To verify the effectiveness of the semantic analysis of the GPT model, we manually checked its standardized output. Out of all the 142 smart contracts, 50 were sampled from the dataset for evaluation. After normalization by the GPT model, 47 results were completely consistent with the original results. Two results show omissions, meaning that the normalized output did not include all the vulnerabilities in the original results. One result shows hallucinations, meaning that the original results did not indicate the existence of the vulnerability, while the normalized output indicated the existence of the vulnerability. The overall performance is shown in Table 4. This result indicates that the GPT model offers great reliability in semantic analyzing textual results and in standardizing output formats.

3.3 Evaluation

We used nine metrics to evaluate the detection results of ChatGPT, namely **true positive (TP)**, **true negative (TN)**, **FP**, **false negative (FN)**, precision, recall, specificity, F1 score and standard deviation. TP and TN represent smart contracts with certain vulnerabilities correctly detected by ChatGPT and smart contracts without certain vulnerabilities, respectively. FP and FN indicate that ChatGPT has incorrectly detected smart contracts with or without certain vulnerabilities. Precision,

Table 5. Comparison of GPT-3.5-Turbo and GPT-4 Detection Results on the Dataset

Vul.	GPT-3.5-turbo					GPT-4o					GPT-4				
	Pre.	Re.	Spec.	F1	Std.	Pre.	Re.	Spec.	F1	Std.	Pre.	Re.	Spec.	F1	Std.
RE	28.3	41.9	77.5	33.8	0.0484	30.0	96.6	43.6	45.8	0.0224	33.5	96.8	41.4	49.8	0.0271
AC	14.3	72.2	20.2	23.9	0.0191	14.4	79.9	40.9	24.4	0.0237	16.7	95.6	29.8	28.4	0.0437
AI	25.8	53.3	77.2	34.8	0.0311	18.0	91.5	61.6	30.0	0.0231	22.0	96.0	63.0	35.7	0.0294
UR	58.5	59.6	73.3	59.0	0.0715	59.0	98.1	69.4	73.6	0.0338	53.6	92.7	67.6	67.9	0.0459
DoS	11.9	83.3	64.0	20.8	0.0195	4.8	96.0	36.6	9.1	0.0121	6.8	96.7	41.9	12.8	0.0168
BR	21.9	87.5	75.4	35.0	0.0800	38.0	100.0	91.9	54.8	0.0622	40.4	98.0	91.0	57.0	0.0418
FR	4.5	25.0	76.8	7.7	0.0000	4.9	70.0	63.9	9.1	0.0358	9.0	70.0	81.2	15.9	0.0080
TM	12.5	40.0	85.4	19.0	0.0088	12.1	100.0	76.6	21.5	0.0296	17.0	88.0	83.2	28.4	0.0447
SAA	0.0	0.0	78.7	0.0	0.0000	0.6	20.0	80.4	1.1	0.0256	4.5	60.0	90.8	8.4	0.0000
Avg.	19.7	51.4	69.8	26.0	0.0309	20.2	83.6	62.8	29.9	0.0298	22.6	88.2	65.5	33.8	0.0286

The values in the table represent percentages, and the column “Std.” represents the standard deviation of the F1 score indicators for five experiments.

recall, specificity, standard deviation and F1 score can be calculated as follows:

$$\text{Precision} = \frac{\#TP}{\#TP + \#FP} \quad (1)$$

$$\text{Recall} = \frac{\#TP}{\#TP + \#FN} \quad (2)$$

$$\text{Specificity} = \frac{\#TN}{\#TN + \#FP} \quad (3)$$

$$F1 = \frac{2 * \text{Precision} * \text{Recall}}{\text{Precision} + \text{Recall}} \quad (4)$$

$$\text{Std.} = \sqrt{\frac{\sum_{i=1}^5 (F1_i - \bar{F1})^2}{5}} \quad (5)$$

The effectiveness of gpt-3.5-turbo in detecting vulnerabilities on the dataset is shown in the left part of Table 5. We repeated the same experiments on the smartbug dataset for five rounds to reduce the impact of the instability of the GPT model.

We replicated the same test by using the model gpt-4o and gpt-4-0613. The middle and right part of Table 7 show the results of these experiments, respectively. It can be seen that gpt-4o and gpt-4 has a significant improvement in the average recall rate of vulnerability detection. However, the precision has not changed much compared to gpt-3.5, leading to only a slight improvement of the overall F1 score.

Furthermore, it is worth noting that while using the gpt-3.5-turbo model, five smart contracts (3.5%) failed to be analyzed. Similarly, during the experimental phase involving the gpt-4 model, two smart contracts (1.4%) encounter detection failures. These instances of detection failure can be attributed to ChatGPT’s token limitations concerning input text. The gpt-3.5-turbo model has a maximum token limit of 4,096, while the gpt-4-0613 model can accommodate up to 8,192 tokens [49]. The length of smart contract codes for these unsuccessful detections exceeded the token threshold.

Finding 2: GPT models may encounter detection failures in long smart contract code due to inherent token limitations.

```

1  pragma solidity ^0.4.15;
2  contract Unprotected{
3      address private owner;
4      modifier onlyowner {
5          require(msg.sender==owner);
6          _;
7      }
8      function Unprotected() public{
9          owner = msg.sender;
10     }
11     function Protected(address _new) onlyowner{
12         owner = _new;
13     }
14 }

```

Listing 1. Example of Using the onlyowner Modifier in Smart Contracts.

Table 5 shows that ChatGPT achieves the best performance in detecting the “*Unchecked Return Values*” vulnerability, with an F-score of 0.59, 0.74 and 0.68, respectively. Except for *Front Running* and *Short Address Attack*, gpt-4 achieves a good recall rate of more than 80% for each type of vulnerability. However, the precision of both models is around 22%, which indicates that ChatGPT has a large number of FP during vulnerability detection.

Finding 3: ChatGPT displays distinct detection performances across various vulnerabilities. Of the 9 vulnerabilities examined, ChatGPT shows its strongest detection performance in detecting “Unchecked Return Values” vulnerability.

3.4 FP Analysis

In order to clarify the reasons for the FP in ChatGPT, we manually analyzed each FP case and classified the reasons for the FP as follows:

Protected Mechanism Bias. We found that most FP generated by ChatGPT stemmed from its excessive attention to the protected mechanisms embedded within the code. In smart contracts, some specific types of vulnerability have related protected mechanisms. For example, to prevent the occurrence of the “Access Control” vulnerability, developers often add relevant modifiers in their code, such as “onlyOwner,” which strictly limits objects that can call specific functions, effectively preventing access control issues.

Listing 1 is an example that uses the “onlyowner” modifier. This contract requires a function that is used to change the owner of this contract, and this function can only be called by the current contract owner. Line 4 is the “onlyowner” modifier. The function to change the contract owner in line 8 is an incorrect example because it is a public function that anyone can call. Line 11 is a correct example, which adds the “onlyowner” modifier to ensure that only the owner of the contract can call. Moreover, to prevent *Arithmetic Issues* vulnerability, developers often add the *SafeMath* [52] library to protect their code. As shown in Listing 2, line 7 is an example of a developer calling the *SafeMath* library to perform arithmetic operations, which can prevent integer overflow vulnerabilities.

```

1 contract Personal_Bank {
2   // Here is the SafeMath library.
3   mapping (address=>uint256) public balances;
4   function Deposit(uint256 amount) public payable {
5     require(amount > 0, "Amount must be greater than 0");
6     // balances[msg.sender] += amount;
7     balances[msg.sender] = balances[msg.sender].add(amount);
8   }
9   function Withdraw(uint256 amount) public payable {
10    require(amount > 0, "Amount must be greater than 0");
11    balances[msg.sender] = balances[msg.sender].sub(amount);
12  }
13 }

```

Listing 2. Example of False Positives in Smart Contracts due to Protected Mechanism Bias.

```

1 function Deposit() public payable{
2   balances[msg.sender]+= msg.value;
3   Log.AddMessage(msg.sender,msg.value,"Put");
4 }

```

Listing 3. Example of False Positive Caused by Insufficient Understanding of “msg.value”.

However, ChatGPT overemphasizes these protected mechanisms. It might flag vulnerabilities (generate FP) in contracts where such protected mechanisms are unnecessary. For example, if a smart contract devoid of arithmetic operations, it inherently avoids integer overflow vulnerabilities. Nevertheless, ChatGPT may incorrectly identify an integer overflow vulnerability in such cases, due to its assumption that the smart contract lacks the SafeMath library. Likewise, certain smart contracts, such as Listing 2, might be designed solely for deposit or withdrawal actions, with no owner-specific functions. Such smart contracts do not necessitate modifiers like “onlyOwner” to defend against vulnerabilities. Unfortunately, ChatGPT does not fully understand this, as it still uses vulnerability protected mechanisms as an important evaluation indicator in many cases and further reports FP when detecting vulnerabilities.

Finding 4: The detection of certain smart contract vulnerabilities by ChatGPT overemphasizes on protected mechanisms in the code, which may produce FP.

Development Intent Bias. In smart contract, variables such as “msg.value” carry specific meanings, signifying the monetary value conveyed by the transaction sender [19]. These variables, unlike general variables, are subject to upper limits determined by factors such as the sender’s available funds and the total currency supply [20]. Consequently, arithmetic operations involving these variables cannot result in overflow concerns. Nevertheless, ChatGPT’s comprehension of this distinction is limited. It treats these variables as conventional ones, incorrectly assuming their modifiability, and thus causing FP regarding integer overflow. As of September 2023, the total

```

1  contract MyContract {
2      mapping(address => uint256) public balances;
3      function transferAndCheck(address to, uint256 amount) internal returns (bool success) {
4          // Check return values.
5          require(balances[msg.sender] >= amount, "Insufficient balance");
6          // Execute transfer operation.
7          balances[msg.sender] -= amount;
8          balances[to] += amount;
9          emit TransferSuccessful(msg.sender, to, amount);
10         success = true;
11     }
12     event TransferSuccessful(address from, address to, uint256 amount);
13     function transferTokens(address to, uint256 amount) public {
14         // Calling the transferAndCheck function.
15         transferAndCheck(to, amount);
16     }
17 }

```

Listing 4. Example of False Positives in Smart Contracts due to Development Intent Bias.

amount of ETH flowing in Ethereum is 24.97M [2], equivalent to approximately 405.6 billion US dollars, with an order of magnitude of 10. However, the threshold for *Arithmetic Issues* is 2 to the 256 power [10], and its order of magnitude is 77. There exists a significant disparity between these two values. Even if the total ETH supply continues to grow, it is highly improbable that the balance of an account or the amount sent in a transaction approaches the *Arithmetic Issues* threshold under normal circumstances. Listing 3 shows the *Deposit* function in a smart contract, and line 2 implements an addition operation. Due to the upper limit of the variable “msg.value,” this statement does not result in the *Arithmetic Issues* vulnerability. However, GPT-4 believed that the contract has an *Arithmetic Issues* vulnerability.

In addition to special variables, some smart contracts may also contain special functions. Listing 4 is an example. The *transferAndCheck* function (line 3) is used to check the return value of the transfer and perform the transfer operation, recording relevant events based on the return results. The function *transferTokens* (line 13) only needs to call the *transferAndCheck* function to execute the transfer, without the need to check the return value of the transfer. This approach can make the code more concise and clear, with centralized processing of return value checking. In fact, many token transfer functions (ERC-20 [18], ERC-721 [17], etc.) in smart contracts are designed in this way. Therefore, such contracts are usually secure, but GPT may believe that there is a *Unchecked Return Values* vulnerability in function *transferTokens* (line 13) due to its development intent bias.

Finding 5: ChatGPT’s analysis of smart contract suffers from development intent bias, resulting in misunderstandings of specific variables and functions, consequently generating FP for certain vulnerabilities.

Table 6. The Proportion of FP Caused by Various Reasons

Reason for FP	Number	Proportion
Protected Mechanism Bias	124	33.1%
Lack of understanding of actual meaning	191	50.9%
Disturbed by comments	11	2.9%
Interference with unexecuted code	45	12.0%
Others	4	1.1%

Interfered by Comments. To aid comprehension, smart contract code typically includes comments written by developers. The content in these comments is usually an explanation of a certain piece of code. However, ChatGPT, as a dialogue model of NLP, cannot distinguish between comments and code itself when analyzing code containing comments. Therefore, it is often interfered with by comments during vulnerability detection. Specifically, when analyzing a piece of code that does not contain vulnerabilities, if the relevant comments contain some logic or statements that contain vulnerabilities, ChatGPT will still determine the code to have vulnerabilities. As shown in Listing 2, a developer originally wrote a “balances[msg.sender] += msg.value;” statement in the code with an Integer Overflow vulnerability (line 6), but found the vulnerability after auditing, changed the original statement to a comment, and correctly added the secure “balances[msg.sender] = balances[msg.sender].add(msg.value);” statement. However, ChatGPT can misinterpret these fragments, yielding FP.

Finding 6: ChatGPT’s vulnerability detection is influenced by code comments, often interpreting them as actual code, leading to potential FP.

Interference with Dead Code. Although some code appears to have some vulnerabilities, this does not mean that the execution of this code is unsafe. Because the code fragment containing the vulnerability may be located in a section that will not be executed, such as within an “if” conditional statement, but this condition will never be met. In actual execution, such vulnerabilities cannot occur, and attackers cannot take the corresponding exploit. However, without the capability to execute code, ChatGPT can misinterpret these fragments, leading to FP.

Finding 7: Due to the lack of actual execution capability of the code, ChatGPT is prone to FP due to some dead code.

Distribution. In addition, we also counted the proportion of FP caused by the above reasons in a total of 375 FP (because each vulnerability generates FPs, some contracts are recalculated) generated by gpt-4 in order to have a more comprehensive understanding of the logic of detecting smart contract vulnerabilities in ChatGPT. The statistical results are shown in Table 6.

In addition to the above reasons, there are also some FP caused by other reasons, represented by “others” in Table 6. It can be seen that the proportion of FP is the highest due to a “lack of understanding of the actual meaning,” indicating that ChatGPT is more likely to generate FP when detecting smart contract vulnerabilities because it cannot understand the actual meaning of code fragments. On the contrary, among the four reasons we identified, the proportion of false positives caused by “comment interference” is the lowest. This is because the smart contracts in the dataset are all from the real world and developers generally do not intentionally leave interfering comments in the code. Nonetheless, this should not undermine the importance of the issue, as it could potentially

be exploited by unscrupulous developers. For example, they may strategically insert seemingly secure comments alongside malicious code to evade vulnerability detection of LLMs.

From the perspective of LLMs, ChatGPT produces FP when detecting smart contract vulnerabilities primarily for the following reasons: (1) Lack of execution context. As an LLM, ChatGPT cannot truly execute code and can only treat code as text, using semantic analysis to detect vulnerabilities [63]. However, for code that only exhibits vulnerabilities under specific execution paths or conditions can easily lead to FP when analyzed semantically alone. Scenarios such as “Interference with Dead Code” and “Interfered by Comments” mentioned fall into this category. (2) Insufficient understanding of specialized semantics. Smart contracts employ certain special variables (e.g., `msg.value`) and functions that differ in meaning and functionality from ordinary variables and functions. Due to the lack of relevant domain knowledge [26], LLMs often struggle to accurately comprehend these specialized semantics, leading to erroneous judgments such as “Development Intent Bias.” (3) Local preference influence. During training, LLMs can form a local preference [37]. In the field of smart contract vulnerability detection, this can be reflected in focusing too much on certain vulnerability protection mechanisms (e.g., *onlyOwner*), leading to excessive reliance on these mechanisms during detection and resulting in biased evaluations. This reflects the locality preference exhibited by LLMs.

Overall, the ability of LLMs to perform domain-specific tasks is constrained by the lack of an execution environment, professional knowledge, and contextual understanding capabilities. Future improvements in their performance on such tasks could be improved by integrating domain knowledge and enhancing model architectures.

Answer to RQ1: Overall, the effectiveness of ChatGPT in detecting vulnerabilities in smart contracts does not satisfy practical applications. It has a high recall rate (51.4% for gpt-3.5-turbo, 83.6% for gpt-4o and 88.2% for gpt-4), but low precision (19.7% for gpt-3.5-turbo, 20.2% for gpt-4o and 22.6% for gpt-4), often giving FP to a smart contract.

4 (RQ2) Comparison with Other Detection Tools

To compare the detection performance of ChatGPT against other tools, we selected 14 smart contract vulnerability detection tools and tested them on the smartbug-cruated dataset. These 14 tools are as follows: Conkas [73], Oyente [42], Smartcheck [67], Honeybadger [70], Maian [45], Securify [72], Slither [22], Osiris [69], Smartian [11], Confuzzius [68], Sailfish [7], Mythril [12], Solhint [54], AChecker [27]. There are three reasons for choosing these 14 tools: (1) Their source code is available. (2) They support to detect at least one type of vulnerability within DASP10. (3) They are published on top venues or widely used by smart contract community.

4.1 Effectiveness

Table 7 shows the detection performance of different tools in the smartbug-cruated dataset. Each tool’s value is represented by F-measure for a specific vulnerability type. Vulnerabilities beyond a tool’s detection scope are marked with “/”. Additionally, the two vulnerabilities *Bad Randomness* and *Short Address Attack* are not supported by all the 14 tools, so they are omitted in Table 7.

The results in Table 7 reveal that ChatGPT’s detection capabilities, particularly for vulnerabilities, such as *Reentrancy* and *Access Control* is not as good as other current tools. However, the performance of ChatGPT is relatively optimal on *Denial of Service* and *Front Running*. This superiority likely derives from the inherent complexity that characterizes these vulnerabilities. *DoS* attacks usually lead to contract failure because of excessive resource use under specific conditions. For example, an attacker might flood the contract with requests, causing it to run out of gas and the failure of execution. *Front Running* involves gaining access to transaction details before they are officially submitted and then taking advantage of this information to maximize profits by

Table 7. Comparison of Detection Performance between ChatGPT and Other Tools

	Reen- trancy	Access Control	Arith- metic Issues	Unchecked Return Values	Denial of Ser- vice	Front Run- ning	Time Manip- ulation
Conkas	44.0%	/	16.8%	91.1%	/	7.7%	27.0%
Oyente	87.5%	0.0%	23.0%	/	3.7%	/	0.0%
Smartcheck	84.1%	18.2%	6.7%	92.9%	7.7%	/	33.3%
Honeybadger	76.0%	/	0.0%	/	/	/	/
Maian	/	51.9%	/	/	/	/	/
Securify	72.0%	8.7%	/	91.7%	/	7.1%	/
Slither	87.0%	23.1%	/	72.7%	10.0%	/	60.0%
Osiris	64.4%	/	28.6%	/	6.7%	/	36.4%
Smartian	30.8%	18.2%	60.0%	84.9%	0.0%	/	23.5%
Confuzzius	76.4%	46.7%	61.1%	86.3%	/	10.5%	/
Sailfish	71.7%	/	/	/	5.9%	5.9%	/
Mythril	37.2%	13.3%	51.4%	67.5%	/	0.0%	/
Solhint	51.3%	27.5%	/	72.7%	0.0%	/	22.7%
AChecker	/	50.0%	/	/	/	/	/
Ave.	65.2%	25.8%	30.6%	82.5%	4.9%	4.7%	29.0%
ChatGPT	49.8%	28.4%	35.7%	67.9%	12.8%	15.9%	28.4%

The bold text in each column highlights the highest F1 score for the corresponding vulnerability.

miners. Due to intricate nature of the two vulnerabilities, it is challenging to define rules to cover all the patterns for them based on traditional program analysis methods. However, ChatGPT's ability to understand code semantics enhances its performance in vulnerability detection. Unlike many program analysis tools that rely on pattern matching, ChatGPT can grasp complex logical structures, making it more effective at detecting vulnerabilities such as *DoS* and *Front Running*. Even so, its F-measure is not very high. It's notable that while 14 selected tools perform better in some types of vulnerability, they are completely unable to detect vulnerability outside their predefined scopes. On the contrary, ChatGPT is not limited to specific vulnerability types and can detect a wider range of vulnerabilities, although success rates may vary. This indicates that ChatGPT has a good breadth in detecting smart contract vulnerabilities, but its accuracy needs to be improved.

Finding 8: Among the nine vulnerabilities that we have examined, ChatGPT demonstrates a notable capability by successfully detecting all nine types of vulnerabilities, showcasing its comprehensive coverage in vulnerability detection.

Finding 9: In comparison to the other 14 tools, ChatGPT demonstrates better detection performance in two vulnerabilities: Denial of Service and Front Running. However, in 3 out of 7 vulnerabilities, the detection performance of ChatGPT is inferior to the average level of other tools.

4.2 Efficiency

The efficiency of these tools is a crucial factor in assessing their practical utility in the field of smart contract security. Therefore, we recorded the time it took for each tool and GPT models to conduct

Table 8. Comparison of Time Performance between ChatGPT and Other Tools in Detecting 142 Smart Contracts on SmartBugs Dataset

Tools	Time (h:m:s)	Errors
Conkas	1:05:23	0
Oyente	0:12:44	0
Smartcheck	0:05:31	0
Honeybadger	1:09:38	0
Maian	2:53:22	0
Securify	0:52:04	0
Slither	0:38:50	0
Osiris	1:11:14	0
Smartian	0:22:44	0
Confuzzius	0:11:23	7
Sailfish	0:25:12	27
Mythril	7:10:02	4
Solhint	0:04:43	0
AChecker	0:06:49	2
gpt-3.5-turbo	0:09:21	5
gpt-4o	0:09:55	5
gpt-4	0:11:09	2

experiments on the entire dataset. It is used as the metric to evaluate their efficiency. Table 8 shows the time performance of various tools and ChatGPT for vulnerability detection on the dataset. In general, the efficiency of ChatGPT is good. gpt-3.5-turbo, gpt-4o and gpt-4 completed the detection of the whole dataset in 9 minutes and 21 seconds, 9 minutes and 55 seconds, 11 minutes and 9 seconds, respectively. It's worth highlighting that the efficiency demonstrated by all three gpt models surpassed that of the other 11 specialized tools (78.6%) listed in Table 8, only inferior to that of *SmartCheck*, *Solhint* and *AChecker*.

Finding 10: In the realm of vulnerability detection, gpt-3.5-turbo, gpt-4o and gpt-4 all excel in terms of efficiency, outperforming 11 out of 14 other tools.

Answer to RQ2: Compared to other tools, ChatGPT can detect more diverse types of vulnerability, but its detection performance score is not very ideal. In addition, ChatGPT outperforms most tools in terms of efficiency.

5 (RQ3) Limitations of ChatGPT in Detecting Vulnerabilities

Although ChatGPT can be used to detect vulnerabilities in smart contracts, it also exhibits many limitations. The first limitation is the uncertainty output. For example, under the same input conditions, ChatGPT may produce different detection results, thus introducing a certain degree of variability. This uncertainty can be derived from the design and training methods of the ChatGPT model.

In addition, the length of the smart contract will also have an impact on the detection performance of ChatGPT. When the contract is too long, ChatGPT may encounter detection failures. This is

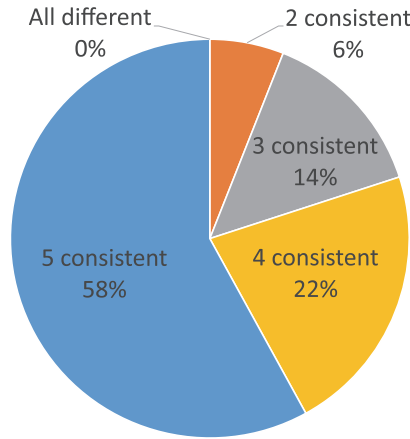


Fig. 3. The uncertainty test results of ChatGPT. Each part displays the number of contracts with consistent results, for example, 5 consistent represents the number of contracts with consistent results from all 5 tests.

because ChatGPT is a pretrained language model, and its input limitations are usually limited by the maximum input length of the model. As shown in Table 8, 5 contracts failed to be detected due to the limitation of the input token of the GPT model, while 10 other tools (71.4%) did not have any failure cases on the dataset. When the contract exceeds the limit on the length of the code, ChatGPT may not be able to fully understand and process the context of the entire contract, resulting in a detection failure.

5.1 Uncertainty

As a language model-based AI model, ChatGPT determines the vulnerabilities in input smart contracts probabilistically. Therefore, even with the same smart contract inputs, ChatGPT might generate divergent vulnerability detection results in different runs. Such variability can be attributed to the model's internal state, randomness, and minuscule input variations.

To delve deeper into ChatGPT's result uncertainty when detecting smart contract vulnerabilities, we randomly selected 50 smart contracts from the dataset and conducted five rounds of vulnerability detections on each of the 50 smart contracts using the gpt-4 model. We then examined the consistency across the five outcomes for every contract. To some extent, for a smart contract, the more consistent the number of results, the stronger the certainty of ChatGPT on the result, and vice versa. The uncertainty of vulnerability detection results of ChatGPT on smart contracts is shown in Figure 3. Each block of Figure 3 displays the number of contracts with consistent results (e.g., 5 consistent represents the number of contracts with consistent results from all 5 tests). In this experiment, we set the confidence level of the results generated by the GPT model to 80% (i.e., if no less than 4 out of 5 results are consistent, we believe that this result is reliable). Among the 50 randomly selected smart contracts, ChatGPT only gave reliable results on 80% of the contracts, while the remaining 20% were unreliable. It can be seen that, in some cases, regardless of whether the conclusion is right or wrong, ChatGPT cannot guarantee the certainty of the conclusion it provides.

GPTScan [62] employs two strategies to mitigate the ambiguity in the responses generated by ChatGPT: adjust the model temperature and employ the "mimic-in-the-background" prompting technique. The former involves setting the temperature parameter of the GPT model to 0, thereby

Table 9. Results After Using Methods to Reduce Uncertainty

	GPT-3.5-turbo			GPT-4		
	Original	Temp-adj	MITB	Original	Temp-adj	MITB
Reentrancy	33.8	54.5 ↑	45.7 ↑	49.8	59.8 ↑	54.1 ↑
Access Control	23.9	29.5 ↑	28.6 ↑	28.4	32.2 ↑	31.7 ↑
Arithmetic Issues	34.8	21.1	30.8	35.7	44 ↑	40 ↑
Unchecked Return Values	59	41.6	34.7	67.9	68.2 ↑	64.4
Denial of Service	20.8	5.9	16.7	12.8	19.4 ↑	16.9 ↑
Bad Randomness	35	7.4	27.3	57	60.9 ↑	52.2
Front Running	7.7	0	0	15.9	7.6	30.8 ↑
Time manipulation	19	28.6 ↑	28.6 ↑	28.4	24	29.6 ↑
Short Address Attack	0	0	0	0	0	22.2 ↑
Avg.	26.0	21.0	23.6	32.9	35.1 ↑	38.0 ↑

“Temp-adj” represents adjusting the temperature to 0; “MITB” represents mimic in-the-background prompting.

ensuring consistent outputs for identical prompts. The latter employs a prompt methodology, leveraging the GPT system’s prompt instruction model to simulate responding to a query five times in the background, ultimately delivering the most frequently recurring response to enhance consistency. Both of these methods contribute to the refinement of ChatGPT’s output results. Hence, we conducted comparative experiments using the same settings and datasets to assess their respective impacts, with detailed results presented in Table 9.

It can be seen that for gpt-3.5-turbo, while both methods can produce some improvements in the detection performance of specific vulnerabilities, the overall efficacy has diminished. In contrast, in the case of gpt-4, these two methods can marginally enhance vulnerability detection performance while maintaining the certainty of the results. This discrepancy may be attributed to the inherent improvements in the gpt-4 architecture, which better leverages these strategies to balance performance and consistency, unlike the earlier gpt-3.5-turbo model.

5.2 Context Length

ChatGPT has token restrictions for contextual input, and it may face detection failure when detecting smart contracts due to the excessively long code length. Despite the token limit guidance provided by GPT, real-world scenarios often introduce various complexities, such as comments, statement lengths, and other factors that can impact the effective code length that the model can handle. Therefore, an experiment was conducted by us to approximate the maximum code size they can accommodate. We calculated the token length of the prompt designed in this study and analyzed the smart contract code that failed detection to explore the threshold code length that the model can detect.

For gpt-4, the maximum number of tokens it can accept is 8192. In this study, the number of tokens occupied by our designed prompt is 107, which means that the maximum length occupied by the input code can be 8085 tokens. We have reviewed two smart contracts that failed detection, with lengths of 2470 and 897 lines of code, and file sizes of 94.4KB and 35.5KB, respectively. Among all successfully detected smart contracts, the longest code length is 771 lines, corresponding to a file size of 27KB. We are attempting to extend the 771 line code by adding some useless comments or code fragments. When the file size reaches 33KB, and the number of code lines reaches 857, gpt-4 detection cannot proceed properly. Similarly, we conducted the same experiment on gpt-3.5 and

found that the maximum smart contract size that the gpt-3.5 model can detect is 16KB. Its value is much lower than gpt-4 because the maximum number of tokens that the gpt-3.5 model can accept is twice that of gpt-4. Therefore, we can draw a rough conclusion that under the experimental conditions of this study, the maximum code size that the gpt-4 model and gpt-3.5 model can detect is around 33KB in file size and 16KB in file size, respectively.

Answer to RQ3: ChatGPT exhibits certain limitations in detecting vulnerabilities in smart contracts, notably in the uncertainty of detection conclusions and the inability to detect lengthy contracts due to token limitations in the model.

6 Discussion

In the course of using ChatGPT for the detection of vulnerability in smart contracts, our article uncovered intriguing phenomena, led to insightful reflections and relevant experiments. First, we delved into ChatGPT's capability to grasp vulnerabilities and showcased the potential for enhancing its detection prowess by injecting external knowledge through illustrative examples. Following that, we embarked on an exploration of multi-round conversation experiments to ascertain whether ChatGPT's multi-round interactions with users wield influence over its vulnerability detection performance. Additionally, we orchestrated code poisoning attack experiments to assess ChatGPT's response to protected mechanisms within the code. Lastly, we orchestrated character obfuscation attack experiments to investigate whether ChatGPT relies solely on character-level semantics for code analysis.

6.1 Vulnerability Learning

Based on the experimental results in Section 3, we found that the effectiveness of ChatGPT in detecting smart contract vulnerabilities is limited. As a pre-trained LLM, ChatGPT may only have limited knowledge of smart contract vulnerabilities. In other words, some new vulnerabilities that appear after a specific date (the date for the corpus used to pre-train the GPT model) cannot be detected by ChatGPT. In addition, if there is less information about a certain vulnerability in the pre-trained data, it will also lead to poor detection performance of ChatGPT for the vulnerability. Therefore, we attempt to identify vulnerabilities with poor ChatGPT detection performance and improve the detection performance of such vulnerabilities by injecting external knowledge. For example, *Price Oracle Manipulation* is a kind of vulnerability with a poor detection effect of ChatGPT. The price oracle machine is a component that can provide asset price data on the chain. Many **decentralized finance (DeFi)** projects will use price oracle machine contracts to obtain prices. The *Price Oracle Manipulation* is to manipulate the price oracle machine through various means to return wrong price data, thereby affecting DeFi projects that rely on these data and causing financial losses.

Listing 5 is a smart contract containing a *Price Oracle Manipulation* vulnerability. The *MyContract* contract obtains (line 9) on chain price data through the *PriceOracle* contract. The *priceFeed* address can be set in *PriceOracle* (line 5). Attackers can set a malicious *priceFeed* address through governance proposals or other methods. The malicious Oracle machine contract can manipulate the price at will, so that key operations in *MyContract* will produce unexpected results. We successively gave five different smart contracts containing this vulnerability to ChatGPT and asked them to detect it. ChatGPT did not detect this vulnerability once. Figure 4 shows the detection results of a certain contract for this vulnerability. This detection result points out two secondary problems in the smart contract while ignoring the main *Price Oracle Manipulation* vulnerability.



There are a couple of vulnerabilities in the provided smart contract:

1. No Check for Negative Prices:

In the `PriceOracle` contract, the `getPrice()` function returns an integer which can be negative. However, in `MyContract`, the `myFunction()` function assigns the potentially negative price to an unsigned integer (`uint`) variable. This can cause underflow if a negative price is returned which could lead to unexpected behaviors or even contract failure.

2. Outdated Compiler Version

The solidity compiler version used in this smart contract is 0.4.19, which is a relatively outdated compiler version. Developers should consider using a higher version of the compiler.

Fig. 4. GPT-4's original detection results of smart contracts containing *Price Oracle Manipulation* vulnerabilities.

```

1  contract PriceOracle {
2    AggregatorV3Interface public priceFeed;
3    constructor(address _priceFeed) {
4      priceFeed = AggregatorV3Interface(_priceFeed); }
5    function getPrice() public view returns (int) {
6      return priceFeed.latestRoundData().answer;}
7  }
8  contract MyContract {
9    PriceOracle priceOracle;
10   function myFunction() external {
11     uint price = priceOracle.getPrice();
12     // Use the variable to perform some key operations.}
13  }
```

Listing 5. Example of Smart Contract Containing *Price Oracle Manipulation* Vulnerability.

The efficacy of employing pre-existing knowledge for directly detecting *Price Oracle Manipulation* vulnerability has been unsatisfactory. Therefore, it is worth exploring the integration of external knowledge as contextual hints within prompts to enhance performance. A key factor is finding the appropriate amount of hints to guide ChatGPT effectively. Therefore, we attempt to improve the detection performance of this vulnerability by injecting external information, and our approach involved categorizing the information in the prompts into three levels to assess ChatGPT's performance (GPT-4 was selected for this experiment): (1) No Information Provided: In the initial tests without specific prompts, ChatGPT failed to identify *Price Oracle Manipulation* vulnerabilities present in 5 smart contracts. (2) Vulnerability Name Only: When the term "Price Oracle Manipulation Vulnerability" was explicitly mentioned in the prompt, ChatGPT successfully detected

 The smart contract you posted has a potential vulnerability in it. Price oracle manipulation vulnerability can occur in the way the getPrice function is set up. It directly returns the latest price from the priceFeed, which can be manipulated if the priceFeed oracle is compromised. This issue could be mitigated by using multiple reliable oracles.

Fig. 5. GPT-4's improved detection results of smart contracts containing *Price Oracle Manipulation* vulnerabilities.

the vulnerability in 2 out of 5 contracts. (3) Vulnerability Name and Code Example: By adopting a technique of providing a few-shot example prompt, which incorporates both the vulnerability name and a code sample, ChatGPT was able to accurately identify the *Price Oracle Manipulation* vulnerability across all 5 smart contracts. Figure 5 shows one of the ChatGPT detection results for this vulnerability after adding external knowledge. This finding suggests that ChatGPT has the ability to incorporate and learn from external knowledge effectively, making it applicable for subsequent detection tasks.

6.2 Multi-Round Conversation

Due to ChatGPT's ability of multiple rounds conversations, we attempted to redo the experiment in this way and add more information during each round of conversations. Figure 6 is an example of a multi-round conversation. We conducted nine successive rounds of conversations with gpt-3.5-turbo. In every interaction, in addition to the name and alias of each vulnerability, we also provide definitions of the vulnerability (information is sourced from the official DASP10 website [75]). ChatGPT acknowledged its awareness of this information upon receiving it in each round of the conversation. Subsequently, we presented a contract source code to ChatGPT for assessment after the conversation rounds. A comparative analysis between the results of this new method and the previous experiment is shown in Figure 7.

The experimental results reveal that there is no obvious enhancement in the detection performance of ChatGPT after multi-round conversation. This observation suggests that the mode of interaction has a limited influence on ChatGPT's capacity to detect vulnerabilities. Compared to the single-round conversation-based experiments, the multi-round conversation-based approach introduced specific vulnerability definitions, thereby furnishing additional information to ChatGPT. Despite this augmentation, upon inspecting the graphical data, it becomes evident that the detection performance scores for certain vulnerability groups, such as "Arithmetic Issues" and "Unchecked Return Values", exhibit a decline rather than an increase. From the perspective of an LLM, several reasons may contribute to this phenomenon. Firstly, while multiple rounds of conversation inject additional external information into the prompt, an overload of information may confuse the model, making it challenging to effectively process a large amount of detailed data. Secondly, external information may be inconsistent or difficult to integrate with ChatGPT's existing knowledge base, resulting in knowledge conflicts. Finally, over-specialization in specific information may diminish the model's ability to generalize across different contexts, thereby impacting vulnerability detection performance. Hence, when using LLMs for tasks, it is crucial to carefully consider the manner and quantity of information provided to mitigate adverse effects on model performance.

6.3 Code Poisoning

As elucidated in Section 3.4, ChatGPT has the risk of generating FP for vulnerabilities in smart contracts due to the absence of protected mechanisms within the code. From the perspective of

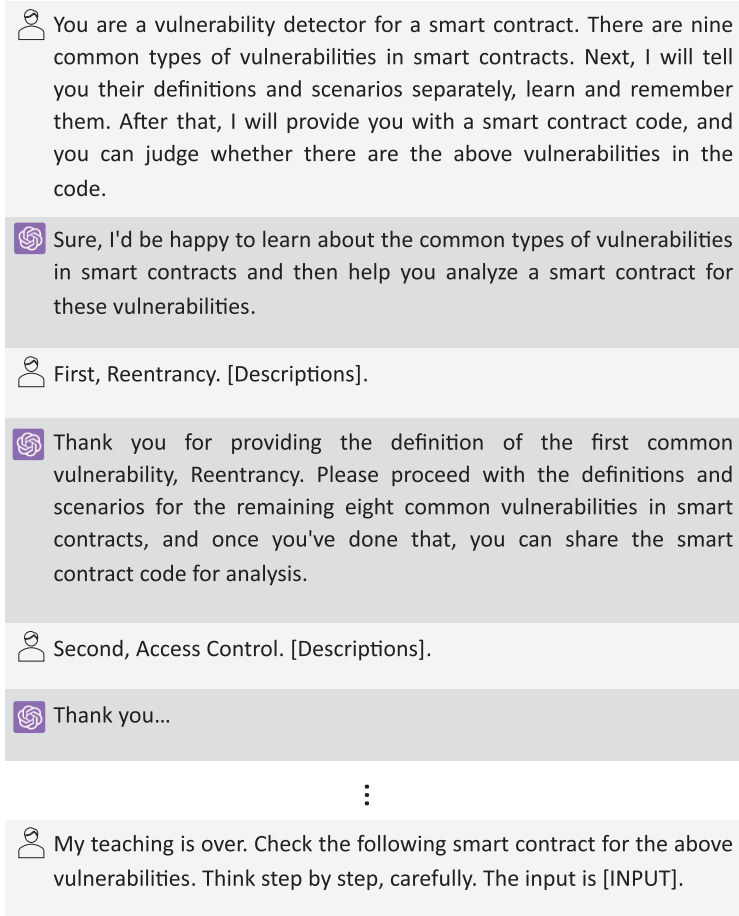


Fig. 6. Schematic diagram for multiple rounds of conversation with ChatGPT.

attackers, they may explore methods to circumvent ChatGPT's vulnerability detection. For example, they could deceive ChatGPT by incorporating protected mechanisms (e.g., *SafeMath*), leading the models to overlook vulnerabilities during detection. In addition, attackers have the ability to incorporate permission control mechanisms, such as the *onlyOwner* modifier, into contracts harboring *Access Control* vulnerability, thus circumventing detection by ChatGPT. To substantiate this notion from an attack-oriented point of view, we conducted an evaluation. Specifically, in all contracts containing *Arithmetical Issues* vulnerability, we artificially added the *SafeMath* library without calling it (i.e., we only added "import SafeMath" to the contract without any other modification, which would not change the logic of the contract). In parallel, we have integrated the *onlyOwner* modifier into all contracts identified with *Access Control* vulnerability where said modifiers were not used. Under this condition, we let the GPT model detect vulnerabilities in these contracts again. In this case, ChatGPT is likely to falsely report the smart contract as negative due to protected mechanism bias.

Table 10 illustrates the results of the code poisoning experiment. The symbol "×" denotes contracts that failed the code poisoning test, which implies that while ChatGPT could have originally identified vulnerabilities within these contracts, it was unable to do so after the protected mechanism

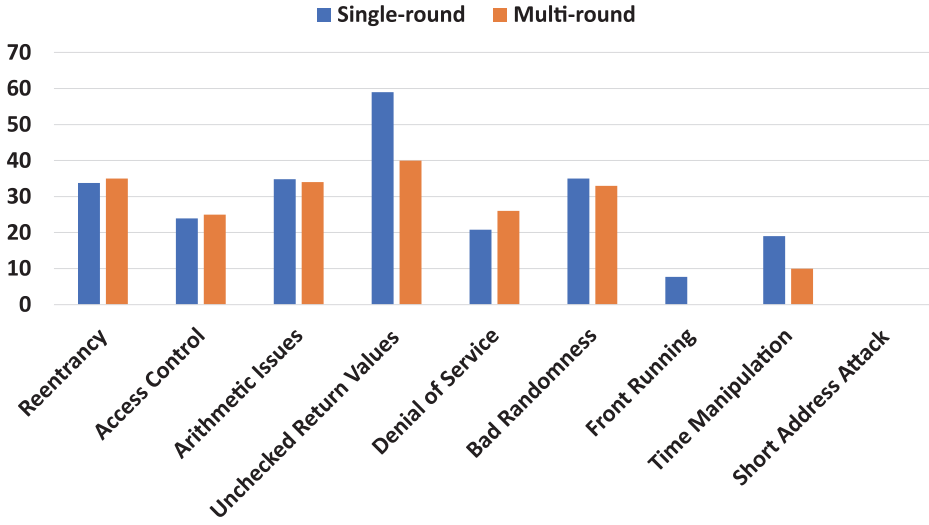


Fig. 7. Experimental results of multi-round conversation.

Table 10. Experimental Results of Code Poisoning

(a) After adding the *SafeMath* library, the detection results of contracts containing *Arithmetic Issues*.

Contract Name	Result
BECToken.sol	×
insecure_transfer.sol	✓
integer_overflow_1.sol	✓
integer_overflow_add.sol	✓
integer_overflow_benign_1.sol	×
mapping_sym_1.sol	✓
integer_overflow_minimal.sol	×
integer_overflow_mul.sol	✓
multitx_multifunc_feasible.sol	×
multitx_onefunc_feasible.sol	✓
overflow_simple_add.sol	✓
overflow_single_tx.sol	✓
timelock.sol	×
token.sol	×
tokensalechallenge.sol	○

(b) After adding the *onlyOwner* modifier, the detection results of contracts containing *Access Control*.

Contract Name	Result
arbitrary_location_write_simple.sol	×
FibonacciBalance.sol	○
incorrect_constructor_name1.sol	×
incorrect_constructor_name2.sol	✓
incorrect_constructor_name3.sol	×
mapping_write.sol	✓
multiowned_vulnerable.sol	×
mycontract.sol	×
parity_wallet_bug_1.sol	○
parity_wallet_bug_2.sol	○
phishable.sol	✓
proxy.sol	×
rubixi.sol	×
simple_suicide.sol	×
unprotected0.sol	×
wallet_02_refund_nosub.sol	✓
wallet_03_wrong_constructor.sol	×
wallet_04_confused_sign.sol	×

Table 11. Comparison of Vulnerability Detection Results (F1 score) Before and After Char Obfuscation

Vulnerability	Raw	Obfuscation
Reentrancy	49.8%	64.2%
Access Control	28.4%	23.5%
Arithmetic Issues	35.7%	51.6%
Unchecked Return Values	67.9%	69.1%
Denial of Service	12.8%	17.9%
Bad Randomness	57.0%	35.0%
Front Running	15.9%	8.0%
Time Manipulation	28.4%	20.5%
Short Address Attack	8.4%	0.0%
Average	33.8%	32.2%

was incorporated. On the other hand, contracts that successfully underwent the code poisoning experiment are indicated by the “✓” symbol. Furthermore, contracts that exhibited an inability to detect vulnerabilities both before and after code poisoning are represented by the “o” symbol. In particular, these results reveal that approximately 46.7% of the smart contracts were influenced by the introduction of *SafeMath* library and 61.1% by that of *onlyOwner* modifier. It should be noted that this experiment, while a simple exploration of code poisoning, underscored the potential for more sophisticated mechanisms to bypass GPT-based detection. It is possible for this to be exploited for malicious purposes.

6.4 Code Confusion Attack

Since code comments can potentially disrupt the functioning of large models (as discussed in Section 3.4), we hypothesize that GPT analyzes code based on its character-level semantics. To explore this hypothesis, we conducted character-obfuscation attack experiments. In this series of experiments, we introduced deliberate obfuscation into each contract within our dataset. Specifically, we applied obfuscation rules to all identifiers within the contracts, including function names and variable names. These rules involved replacing certain characters with visually similar glyphs (i.e., “l” with “1”, “o” with “0”, “i” with “l”, “s” with “5”, “g” with “9”), and if the replaced identifier began with a number, we prepended an underscore before the number. The experimental results following this obfuscation process are presented in Table 11.

After applying character obfuscation, the detection performance of only four vulnerabilities (44.4%) decreased, indicating susceptibility to obfuscation attacks. Surprisingly, the detection performance of the remaining five vulnerabilities remained relatively stable or even showed slight improvements. Although our study shows that character obfuscation has varying effects on different vulnerabilities and a limited impact on the overall average performance of vulnerability detection, it is important to note that the underlying mechanisms explaining these observations are beyond the scope of this article. Further in-depth research is needed to explore these underlying principles.

7 Related Work

7.1 Vulnerability Detection

In recent years, there have been many related works on vulnerability detection in smart contracts. A variety of tools and approaches have been used to pinpoint vulnerabilities in the ecosystem of smart contracts. A prevalent methodology is static verification, which evaluates the source code

or bytecode without running it [8, 9, 23, 35, 75]. On the other hand, dynamic analysis provides more profound discernment by surveying smart contracts during execution. Automated tools, such as fuzzing [29, 32, 76] can generate input to comprehensively assess the performance of the system. Symbolic execution [12, 24, 44, 44] and formal verification [53, 61] are commended for their effectiveness, although formal verification characteristically requires specifications given by the user. Furthermore, Zheng et al. [79] investigated the effectiveness of various current tools in detecting reentry vulnerabilities and summarized the reasons for their FP. In summary, automated tools and techniques can be used to uncover potential vulnerabilities in smart contracts. Recent studies have pioneered new techniques for identifying profitable manipulations and security threats in DeFi systems. Novel methodologies utilizing dynamic program analysis from Qin et al. [55, 57] can automatically replicate and synthesize money-making transactions on blockchains in real time. Such techniques could be deployed after smart contracts are released to serve as on-chain intrusion monitoring. Other works like DeFiPoser [80] have introduced universal frameworks to detect attack vectors in DeFi by modeling protocol logic and employing algorithms like Z3 or Bellman-Ford. LLMs also show the potential for anomaly detection in blockchain networks when properly trained [25]. Advanced representations such as Qin et al. [56] execution property graphs can encode runtime details to complement static analysis and improve security for smart contracts in online and forensic settings. In summary, cutting-edge studies are pushing the boundaries of dynamically analyzing, modeling, and securing DeFi ecosystems against exploitation.

7.2 LLMs

Due to the rise of large models, many scholars have recently conducted in-depth research on them. Ma et al. [43] evaluated the performance of ChatGPT in various subdomains of software engineering. David et al. [14] studied the detection ability of large models such as *Claude* [5] and *GPT* [47] for actual attacks on smart contracts. Unlike this, our research focused on several common vulnerabilities in the field of smart contracts, evaluated the effectiveness and limitations of ChatGPT in detecting smart contract vulnerabilities, analyzed the reasons why ChatGPT produced FP, and compared it with other tools. Li et al. [38] studied the limitations of LLMs in generating software failure-induced test cases and proposed a differential prompt method to improve effectiveness. Fan et al. [21] studied whether automatic program repair technology can fix the error solutions generated by LLMs in the *LeetCode* competition. Wang et al. [74] analyzed 52 related studies using LLM for software testing from the perspective of software testing. Joshi et al. presented an LLM-based approach to multilingual repair that enables a flipped interaction model for AI-assisted programming in which the user writes code, and the assistant suggests fixes for last-mile mistakes [33].

8 Conclusion and Future Works

In this article, we assessed ChatGPT's capability in detecting smart contract vulnerability. We formulated three RQs to explore the efficacy of ChatGPT in detecting smart contract vulnerabilities, compare it with other vulnerability detection tools, and identify limitations in its performance. For RQ1, we devised an optimized prompt to acquire ChatGPT's detection outcomes, consisting of two steps: vulnerability detection and semantic analysis. The findings suggest that, although ChatGPT demonstrated strengths in pinpointing certain vulnerabilities, it also encountered precision-related challenges. We conducted an analysis of the root causes behind ChatGPT's FP, categorizing them into four distinct groups. For RQ2, we ran other 14 state-of-the-art vulnerability detection tools on the dataset, and compared ChatGPT with them, revealing that although ChatGPT can detect the most types of vulnerability, the detection performance of ChatGPT is not as good as other state-of-the-art tools for 71.4% (5/7) of vulnerabilities. ChatGPT demonstrates excellent efficiency but also exhibits

a higher proportion of detection failures compared to 71.4% (10/14) of the tools we evaluated. For RQ3, we evaluated the uncertainty of ChatGPT by submitting the same smart contract to the model for multiple vulnerability detection and recording the frequency of consistent conclusions. The results indicate that approximately 20% of the conclusions are uncertain. Additionally, we employed ChatGPT to assess smart contracts of varying lengths, aiming to determine the file size threshold that the model can effectively analyze. We conclude that the maximum code size that the gpt-4 model and gpt-3.5 model can detect is around 33KB in file size and 16KB in file size, respectively. These findings underscore its potential as a vulnerability detection tool, but improvements are still needed for a broader adoption in blockchain security.

In the future, we intend to dive deeper into exploring the capabilities of alternative LLMs for smart contract vulnerability detection, including but not limited to *Code llama* [58]. Furthermore, our objectives include leveraging more intricate and diverse datasets to further test the capabilities boundary of LLMs within this domain. We also plan to apply techniques such as fine-tuning [31] and retrieval-augmented generation [36] to enhance the performance of ChatGPT in detecting smart contract vulnerabilities. Furthermore, as new versions of LLMs become available, we will reevaluate our research using these updated models.

References

- [1] Chat-Yuan. 2023. Retrieved from <https://modelscope.cn/studios/ClueAI/ChatYuan-large-v2/summary>
- [2] Ethereum. 2023. Retrieved from <https://ethereum.org/en/>
- [3] Xunfei-Xinghuo. 2023. Retrieved from <https://xinghuo.xfyun.cn/>
- [4] Rohan Anil, Andrew M. Dai, Orhan Firat, Melvin Johnson, Dmitry Lepikhin, Alexandre Passos, Siamak Shakeri, Emanuel Taropa, Paige Bailey, Zhifeng Chen, et al. 2023. PaLM 2 Technical Report. arXiv:2305.10403. Retrieved from <https://arxiv.org/abs/2305.10403>
- [5] Anthropic. 2023. Claude. Retrieved from <https://claude.ai/chats>
- [6] S. Biswas. 2023. Role of ChatGPT in computer programming. *Mesopotamian Journal of Computer Science* (2023), 8–16. DOI : <https://doi.org/10.58496/MJCSC/2023/002>
- [7] Priyanka Bose, Dipanjan Das, Yanju Chen, Yu Feng, Christopher Kruegel, and Giovanni Vigna. 2022. Sailfish: Vetting smart contract state-inconsistency bugs in seconds. In *Proceedings of the IEEE Symposium on Security and Privacy (SP)*. IEEE, 161–178.
- [8] Lexi Brent, Neville Grech, Sifis Lagouvardos, Bernhard Scholz, and Yannis Smaragdakis. 2020. Ethainter: A smart contract security analyzer for composite vulnerabilities. In *Proceedings of the 41st ACM SIGPLAN Conference on Programming Language Design and Implementation (PLDI '20)*. ACM, New York, NY, 454–469. DOI : <https://doi.org/10.1145/3385412.3385990>
- [9] Lexi Brent, Anton Jurisevic, Michael Kong, Eric Liu, Francois Gauthier, Vincent Gramoli, Ralph Holz, and Bernhard Scholz. 2018. Vandal: A scalable security analysis framework for smart contracts. arXiv:1809.03981. Retrieved from <https://arxiv.org/abs/1809.03981>
- [10] Jiachi Chen, Mingyuan Huang, Zewei Lin, Peilin Zheng, and Zibin Zheng. 2023. To healthier ethereum: A comprehensive and iterative smart contract weakness enumeration. arXiv:2308.10227. Retrieved from <https://arxiv.org/abs/2308.10227>
- [11] Jaeseung Choi, Doyeon Kim, Soomin Kim, Gustavo Grieco, Alex Groce, and Sang Kil Cha. 2021. Smartian: Enhancing smart contract fuzzing with static and dynamic data-flow analyses. In *Proceedings of the 36th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. IEEE, 227–239.
- [12] ConsenSys. 2021. Consensys/Mythril: Security Analysis Tool for EVM Bytecode. Retrieved from <https://github.com/ConsenSys/mythril>
- [13] Chris Dannen. 2017. *Introducing Ethereum and Solidity*. Vol. 1. Springer.
- [14] Isaac David, Liyi Zhou, Kaihua Qin, Dawn Song, Lorenzo Cavallaro, and Arthur Gervais. 2023. Do you still need a manual smart contract audit? arXiv:2306.12338. Retrieved from <https://arxiv.org/abs/2306.12338>
- [15] Zhengxiao Du, Yujie Qian, Xiao Liu, Ming Ding, Jiezhong Qiu, Zhilin Yang, and Jie Tang. 2022. GLM: General language model pretraining with autoregressive blank infilling. In *Proceedings of the 60th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, 320–335.
- [16] Thomas Durieux, João F. Ferreira, Rui Abreu, and Pedro Cruz. 2020. Empirical review of automated analysis tools on 47,587 Ethereum smart contracts. In *Proceedings of the ACM/IEEE 42nd International Conference on Software Engineering*, 530–541.

- [17] William Entriken, Dieter Shirley, Jacob Evans, and Nastassia Sachs. 2018. ERC-721: Non-Fungible Token Standard. Retrieved from <https://eips.ethereum.org/EIPS/eip-721>
- [18] Ethereum. 2023. ERC-20 Token Standard. Retrieved from <https://ethereum.org/en/developers/docs/standards/tokens/erc-20/>
- [19] Ethereum. 2023. Solidity Documentation. Retrieved from <https://docs.soliditylang.org/en/v0.8.21/>
- [20] Ethereum. 2023. Units and Globally Available Variables. Retrieved from <https://docs.soliditylang.org/en/develop/units-and-global-variables.html>
- [21] Zhiyu Fan, Xiang Gao, Martin Mirchev, Abhik Roychoudhury, and Shin Hwei Tan. 2023. Automated repair of programs from large language models. In *Proceedings of the IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. IEEE, 1469–1481.
- [22] Josselin Feist, Gustavo Grieco, and Alex Groce. 2019. Slither: A static analysis framework for smart contracts. In *Proceedings of the IEEE/ACM 2nd International Workshop on Emerging Trends in Software Engineering for Blockchain (WETSEB)*. IEEE, 8–15.
- [23] João F Ferreira, Pedro Cruz, Thomas Durieux, and Rui Abreu. 2020. SmartBugs: A framework to analyze solidity smart contracts. In *Proceedings of the 35th IEEE/ACM International Conference on Automated Software Engineering*, 1349–1352.
- [24] Joel Frank, Cornelius Aschermann, and Thorsten Holz. 2020. ETHBMC: A bounded model checker for smart contracts. In *Proceedings of the 29th USENIX Security Symposium (USENIX Security 20)*. USENIX Association, 2757–2774. Retrieved from <https://www.usenix.org/conference/usenixsecurity20/presentation/frank>
- [25] Yu Gai, Liyi Zhou, Kaihua Qin, Dawn Song, and Arthur Gervais. 2023. Blockchain large language models. arXiv:2304.12749. Retrieved from <https://arxiv.org/abs/2304.12749>
- [26] Yingqiang Ge, Wenyue Hua, Kai Mei, jianchao ji, Juntao Tan, Shuyuan Xu, Zelong Li, and Yongfeng Zhang. 2023. OpenAGI: When LLM meets domain experts. In *Proceedings of the 37th International Conference on Neural Information Processing Systems*. A. Oh, T. Neumann, A. Globerson, K. Saenko, M. Hardt, and S. Levine (Eds.), Vol. 36. Curran Associates, Inc., 5539–5568. Retrieved from https://proceedings.neurips.cc/paper_files/paper/2023/file/1190733f217404edc8a7f4e15a57f301-Paper-Datasets_and_Benchmarks.pdf
- [27] Asem Ghaleb, Julia Rubin, and Karthik Pattabiraman. 2023. Achecker: Statically detecting smart contract access control vulnerabilities. In *Proceedings of the IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. IEEE, 945–956.
- [28] Puneet Gill, Indrani Ray, Alireza Lotfi Takami, and Mahesh Tripunitara. 2022. Finding unchecked low-level calls with zero false positives and negatives in ethereum smart contracts. In *Proceedings of the International Symposium on Foundations and Practice of Security*. Springer, 305–321.
- [29] Gustavo Grieco, Will Song, and Artur Cygan. 2020. Echidna: Effective, usable, and fast fuzzing for smart contracts. In *Proceedings of the 29th ACM SIGSOFT International Symposium on Software Testing and Analysis*. ACM, New York, NY, 787–801. Retrieved from <https://agroce.github.io/issta20.pdf>
- [30] Daojing He, Zhi Deng, Yuxing Zhang, Sammy Chan, Yao Cheng, and Nadra Guizani. 2020. Smart contract vulnerability analysis and security audit. *IEEE Network* 34, 5 (2020), 276–282. DOI: <https://doi.org/10.1109/MNET.001.1900656>
- [31] Jeremy Howard and Sebastian Ruder. 2018. Universal language model fine-tuning for text classification. arXiv:1801.06146. Retrieved from <https://arxiv.org/abs/1801.06146>
- [32] Bo Jiang, Ye Liu, and WK Chan. 2018. Contractfuzzer: Fuzzing smart contracts for vulnerability detection. In *Proceedings of the 33rd ACM/IEEE International Conference on Automated Software Engineering*. ACM, New York, NY, 259–269. DOI: <https://doi.org/10.1145/3238147.3238177>
- [33] Harshit Joshi, José Cambronero Sanchez, Sumit Gulwani, Vu Le, Gust Verbruggen, and Ivan Radiček. 2023. Repair is nearly generation: Multilingual program repair with LLMs. *Proceedings of the AAAI Conference on Artificial Intelligence* 37, 4 (Jun. 2023), 5131–5140. DOI: <https://doi.org/10.1609/aaai.v37i4.25642>
- [34] Leslie Pack Kaelbling, Michael L Littman, and Andrew W Moore. 1996. Reinforcement learning: A survey. *Journal of Artificial Intelligence Research* 4 (1996), 237–285.
- [35] Sukrit Kalra, Seep Goel, Mohan Dhawan, and Subodh Sharma. 2018. Zeus: Analyzing safety of smart contracts. In *Proceedings of the Network and Distributed System Security (NDSS) Symposium*, 1–12.
- [36] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Kütler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, et al. 2020. Retrieval-augmented generation for knowledge-intensive nlp tasks. In *Proceedings of the 34th International Conference on Neural Information Processing Systems*, 9459–9474.
- [37] Junlong Li, Fan Zhou, Shichao Sun, Yikai Zhang, Hai Zhao, and Pengfei Liu. 2024. Dissecting human and LLM preferences. arXiv:2402.11296. Retrieved from <https://arxiv.org/abs/2402.11296>
- [38] T. Li, W. Zong, Y. Wang, H. Tian, Y. Wang, S. Cheung, and J. Kramer. 2023. *Finding Failure-Inducing Test Cases with ChatGPT*. IEEE.

- [39] Tianyang Lin, Yuxin Wang, Xiangyang Liu, and Xipeng Qiu. 2022. A survey of transformers. *AI Open* 3 (2022), 111–132. 2666–6510 DOI : <https://doi.org/10.1016/j.aiopen.2022.10.001>
- [40] Peng Liu, Weizhen Yuan, Jie Fu, Zhengbao Jiang, Hiroaki Hayashi, and Graham Neubig. 2023. Pre-train, prompt, and predict: A systematic survey of prompting methods in natural language processing. *ACM Computing Surveys* 55, 9 (2023), 1–35.
- [41] Itemperance Consulting Pvt. Ltd. 2023. gpt-3-vs-gpt-3-5. Retrieved from <https://www.iffort.com/2023/03/31/gpt-3-vs-gpt-3-5>.
- [42] Loi Luu, Duc-Hiep Chu, Hrishi Olickel, Prateek Saxena, and Aquinas Hobor. 2016. Making smart contracts smarter. In *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, ACM, New York, NY, 254–269. DOI : <https://doi.org/10.1145/2976749.2978309>
- [43] Wei Ma, Shangqing Liu, Wenhan Wang, Qiang Hu, Ye Liu, Cen Zhang, Liming Nie, and Yang Liu. 2023. The scope of ChatGPT in software engineering: A thorough investigation. arXiv:2305.12138.
- [44] Mark Mossberg, Felipe Manzano, Eric Hennenfent, Alex Groce, Gustavo Grieco, Josselin Feist, Trent Brunson, and Artem Dinaburg. 2019. Manticore: A user-friendly symbolic execution framework for binaries and smart contracts. In *Proceedings of the 34th IEEE/ACM International Conference on Automated Software Engineering (ASE)*, 1186–1189. DOI : <https://doi.org/10.1109/ASE.2019.00133>
- [45] Ivica Nikolić, Aashish Kolluri, Ilya Sergey, Prateek Saxena, and Aquinas Hobor. 2018. Finding the greedy, prodigal, and suicidal contracts at scale. In *Proceedings of the 34th Annual Computer Security Applications Conference*, 653–663.
- [46] OpenAI. 2023. GPT-3.5. Retrieved from <https://platform.openai.com/docs/models/gpt-3-5>
- [47] OpenAI. 2023. GPT-4. Retrieved from <https://platform.openai.com/docs/models/gpt-4>
- [48] OpenAI. 2023. GPT-4 technical report. arXiv:2303.08774. Retrieved from <https://arxiv.org/abs/2303.08774>
- [49] OpenAI. 2023. GPT-OpenAI API. Retrieved from <https://platform.openai.com/docs/guides/gpt>
- [50] OpenAI. 2023. research-gpt4. Retrieved from <https://openai.com/research/gpt-4>
- [51] OpenAI. 2024. GPT-4o. Retrieved from <https://openai.com/index/hello-gpt-4o/>
- [52] Openzeppelin solidity. 2018. SafeMath. Retrieved from <https://github.com/ConsensysMesh/openzeppelin-solidity/blob/master/contracts/math/SafeMath.sol>
- [53] Anton Permenev, Dimitar Dimitrov, Petar Tsankov, Dana Drachler-Cohen, and Martin Vechev. 2020. VerX: Safety Verification of Smart Contracts. In *Proceedings of the IEEE Symposium on Security and Privacy (SP)*, 1661–1677. DOI : <https://doi.org/10.1109/SP40000.2020.00024>
- [54] Protofire. 2020. Solhint. Retrieved from <https://github.com/protofire/solhint>
- [55] Kaihua Qin, Stefanos Chaliasos, Liyi Zhou, Benjamin Livshits, Dawn Song, and Arthur Gervais. 2023. The blockchain imitation game. In *Proceedings of the USENIX Security Symposium*.
- [56] Kaihua Qin, Zhe Ye, Zhun Wang, Weilin Li, Liyi Zhou, Chao Zhang, Dawn Song, and Arthur Gervais. 2023. Towards automated security analysis of smart contracts based on execution property graph. arXiv:2305.14046. Retrieved from <https://arxiv.org/abs/2305.14046>
- [57] Kaihua Qin, Liyi Zhou, and Arthur Gervais. 2022. Quantifying blockchain extractable value: How dark is the forest?. In *Proceedings of the IEEE Symposium on Security and Privacy (SP)*. IEEE, 198–214.
- [58] Baptiste Rozière, Jonas Gehring, Fabian Gloeckle, Sten Sootla, Itai Gat, Xiaoqing Ellen Tan, Yossi Adi, Jingyu Liu, Tal Remez, Jérémy Rapin, et al. 2023. Code Llama: Open foundation models for code. arXiv:2308.12950. Retrieved from <https://arxiv.org/abs/2308.12950>
- [59] Sarwar Sayeed, Hector Marco-Gisbert, and Tom Caira. 2020. Smart contract: Attacks and protections. *IEEE Access* 8 (2020), 24416–24427. DOI : <https://doi.org/10.1109/ACCESS.2020.2970495>
- [60] Nigar M. Shafiq Surameery and Mohammed Y. Shakor. 2023. Use Chat GPT to solve programming bugs. *International Journal of Information Technology & Computer Engineering* 3, 1 (Jan. 2023), 17–22. 2455–5290. DOI : <https://doi.org/10.55529/ijitc.31.17.22>
- [61] Sunbeom So, Myunggho Lee, Jisu Park, Heejo Lee, and Hakjoo Oh. 2019. VeriSmart: A highly precise safety verifier for ethereum smart contracts. arXiv:1908.11227. Retrieved from <https://arxiv.org/abs/1908.11227>
- [62] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Haijun Wang, Zhengzi Xu, Xiaofei Xie, and Yang Liu. 2023. When gpt meets program analysis: Towards intelligent detection of smart contract logic vulnerabilities in gptscan. arXiv:2308.03314. Retrieved from <https://arxiv.org/abs/2308.03314>
- [63] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Haijun Wang, Zhengzi Xu, Xiaofei Xie, and Yang Liu. 2024. GPTScan: Detecting logic vulnerabilities in smart contracts by combining GPT with program analysis. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering (ICSE '24)*. ACM, New York, NY, Article 166, 13 pages. DOI : <https://doi.org/10.1145/3597503.3639117>
- [64] Nick Szabo. 1997. Formalizing and securing relationships on public networks. *First Monday* 2, 9 (1997). DOI : <https://doi.org/10.5210/fm.v2i9.548>
- [65] Google team. 2023. Google. Retrieved from <https://about.google/>

- [66] OpenAI team. 2023. OpenAI. Retrieved from <https://openai.com/>
- [67] Sergei Tikhomirov, Ekaterina Voskresenskaya, Ivan Ivanitskiy, Ramil Takhaviev, Evgeny Marchenko, and Yaroslav Alexandrov. 2018. Smartcheck: Static analysis of ethereum smart contracts. In *Proceedings of the 1st International Workshop on Emerging Trends in Software Engineering for Blockchain*, 9–16.
- [68] Christof Ferreira Torres, Antonio Ken Iannillo, Arthur Gervais, and Radu State. 2021. Confuzzius: A data dependency-aware hybrid fuzzer for smart contracts. In *Proceedings of the IEEE European Symposium on Security and Privacy (EuroS & P)*. IEEE, 103–119.
- [69] Christof Ferreira Torres, Julian Schütte, and Radu State. 2018. Osiris: Hunting for integer bugs in ethereum smart contracts. In *Proceedings of the 34th Annual Computer Security Applications Conference*, 664–676.
- [70] Christof Ferreira Torres, Mathis Steichen, and Radu State. 2019. The art of the scam: Demystifying honeypots in ethereum smart contracts. In *Proceedings of the USENIX Security Symposium (USENIX Security 19)*, 1591–1607.
- [71] Hugo Touvron, Thibaut Lavril, Gautier Izacard, Xavier Martinet, Marie-Anne Lachaux, Timothée Lacroix, Baptiste Rozière, Naman Goyal, Eric Hambro, Faisal Azhar, et al. 2023. LLaMA: Open and efficient foundation language models. arXiv:2302.13971. Retrieved from <https://arxiv.org/abs/2302.13971>
- [72] Petar Tsankov, Andrei Dan, Dana Drachsler-Cohen, Arthur Gervais, Florian Buenzli, and Martin Vechev. 2018. Securify: Practical security analysis of smart contracts. In *Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security*, ACM, New York, NY, 67–82. DOI: <https://doi.org/10.1145/3243734.3243780>
- [73] Nuno Veloso. 2021. Conkas. Retrieved from <https://github.com/nveloso/conkas>
- [74] Junjie Wang, Yuchao Huang, Chunyang Chen, Zhe Liu, Song Wang, and Qing Wang. 2023. Software testing with large language model: Survey, landscape, and vision. arXiv:2307.07221. Retrieved from <https://arxiv.org/abs/2307.07221>
- [75] David Wong and Mason Hemmel. 2018. Decentralized Application Security Project Top 10 of 2018. Retrieved from <https://dasp.co/index.html>
- [76] Valentin Wustholz and Maria Christakis. 2020. Harvey: A greybox fuzzer for smart contracts. In *Proceedings of the 28th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. ACM, New York, NY, 1398–1409. DOI: <https://doi.org/10.1145/3368089.3417064>
- [77] Yue Zhang, Ming Zhang, Haipeng Yuan, Shichun Liu, Yongyao Shi, Tao Gui, Qi Zhang, and Xuanjing Huang. 2024. Llmeval: A preliminary study on how to evaluate large language models. In *Proceedings of the AAAI Conference on Artificial Intelligence*, Vol. 38, 19615–19622.
- [78] Zibin Zheng, Shaoan Xie, Hong-Ning Dai, Weili Chen, Xiangping Chen, Jian Weng, and Muhammad Imran. 2020. An overview on smart contracts: Challenges, advances and platforms. *Future Generation Computer Systems* 105 (2020), 475–491.
- [79] Z. Zheng, N. Zhang, J. Su, Z. Zhong, M. Ye, and J. Chen. 2023. Turn the rudder: A beacon of reentrancy detection for smart contracts on ethereum. In *Proceedings of the 45th International Conference on Software Engineering*.
- [80] Liyi Zhou, Kaihua Qin, Antoine Cully, Benjamin Livshits, and Arthur Gervais. 2021. On the just-in-time discovery of profit-generating transactions in DeFi protocols. arXiv:2103.02228. Retrieved from <https://arxiv.org/abs/2103.02228>

Received 11 September 2023; revised 14 August 2024; accepted 11 October 2024